

บทที่ 3

การออกแบบและพัฒนา

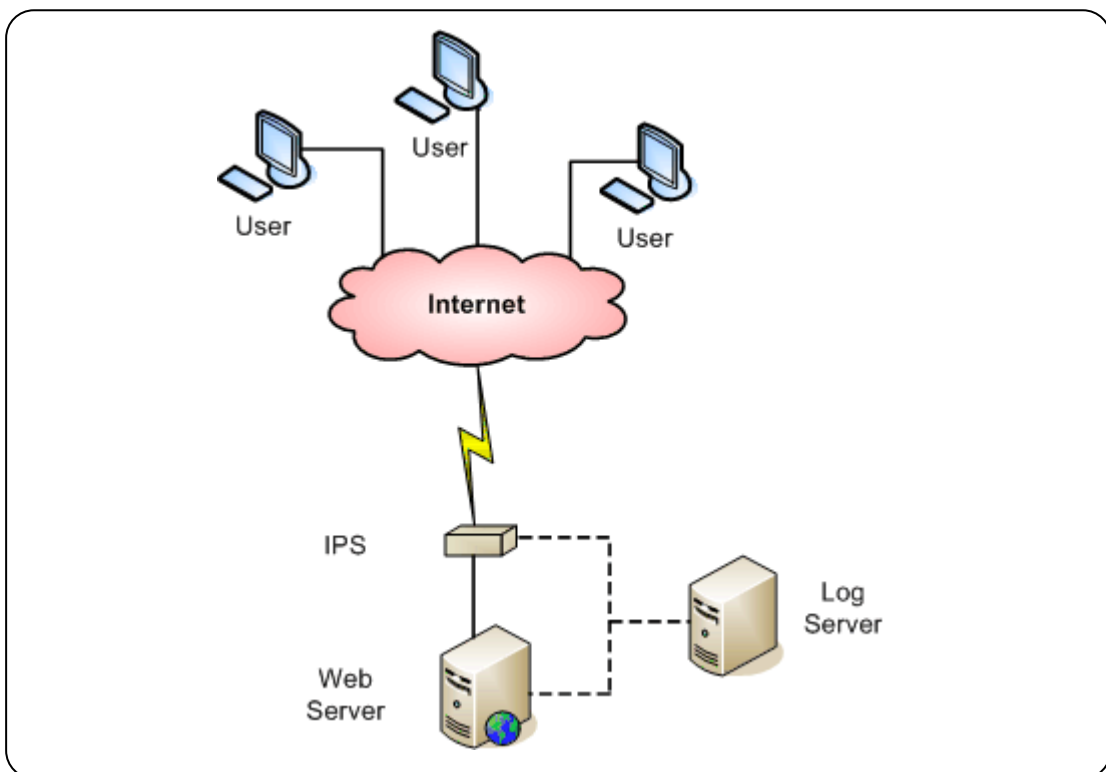
3.1 บทนำ

ในส่วนของการออกแบบและพัฒนานั้นจะต้องมีการพิจารณาถึงองค์ประกอบต่างๆ ที่จะนำมารวมและสร้างเป็นระบบขึ้น เพื่อให้ทำงานได้ตามเป้าหมายที่วางไว้ โดยในส่วนต่างๆ นั้นได้มีการพิจารณาอย่างเหมาะสม

นอกจากนั้นสิ่งสำคัญที่จะต้องนำมาพิจารณาคือ ความปลอดภัยของระบบ ทั้งนี้ระบบที่สร้างขึ้นจะต้องมีความปลอดภัยในตัวเองในระดับหนึ่ง ดังนั้นการออกแบบจึงต้องมีความรัดกุมและรอบคอบมากที่สุด โดยรายละเอียดของการออกแบบในแต่ละส่วนนั้นจะอธิบายในหัวข้อถัดไปซึ่งแยกเป็น การออกแบบฮาร์ดแวร์ และการออกแบบซอฟต์แวร์

3.2 การออกแบบฮาร์ดแวร์

โครงสร้างของระบบมีการออกแบบดังรูปภาพ



รูปที่ 3.1 แสดงโครงสร้างของระบบที่ได้ทำการออกแบบไว้

จากรูปภาพแสดงให้เห็นส่วนประกอบต่างๆ ของระบบ โดยประกอบไปด้วย

- IPS ทำหน้าที่ตรวจจับการบุกรุกและทำหน้าที่ในการตอบสนองเบื้องต้น
- Web Server เป็น Server ที่ให้บริการเว็บ
- Log Server เป็น Server สำหรับเก็บ log file ทั้งหมดที่ได้จาก IPS และ Log Server

3.3 การออกแบบซอฟต์แวร์

ในการออกแบบซอฟต์แวร์จะแบ่งออกเป็น 3 ส่วนดังนี้คือ Sensor and Audit , Forensic และ Recovery

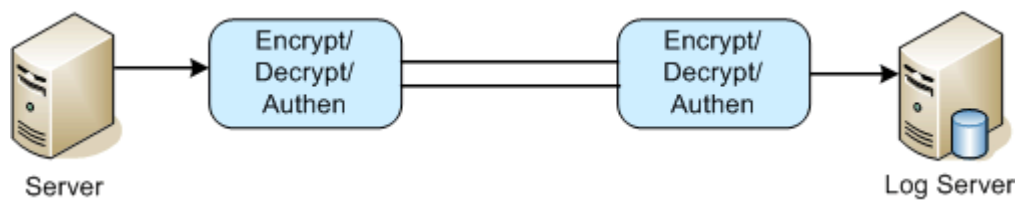
3.1.1 Sensor and Audit

การเก็บข้อมูล

เนื่องจากโดยปกติของพฤติกรรม ผู้บุกรุกนั้น เมื่อทำการละเมิดสิทธิ์ หรือ บุกรุกเข้ามาสู่เครื่องเราได้แล้วสิ่งที่จะทำต่อไปก็คือ ดำรงเก็บข้อมูล วางช่องทางเอาไว้เพื่อที่จะได้กลับเข้ามาสู่เครื่องเราอีกได้ตามที่ต้องการ และสิ่งสุดท้ายที่ผู้บุกรุกจะทำก็คือการทำลายหลักฐานเพื่อไม่ให้เจ้าของเครื่องหรือระบบรับรู้ถึงความผิดปกติ และ ถึงจะรู้ถึงสิ่งผิดปกติก็ไม่สามารถที่จะ สืบหาข้อมูล ได้ว่าเกิดอะไรขึ้นกับเครื่องบ้าง ใครเข้ามาทำอะไรเครื่องเรา และยากที่จะตัดสินใจได้ว่า ควรจะแก้ไขอย่างไรจากสิ่งต่างๆดังที่ได้กล่าวมานี้จึงทำให้เกิด ระบบ centralize หรือการเก็บข้อมูลไว้ที่เครื่องกลางที่ทำหน้าที่ในการเก็บหลักฐานต่างที่ส่งมาจากเครื่องอื่นๆ เพื่อหลีกเลี่ยงการทำลายหลักฐานต่างๆ จึงได้ออกแบบให้มีการส่งข้อมูล ล็อกไฟล์ และข้อมูลทาง network หรือแม้กระทั่งข้อมูลภายในของเครื่องไปเก็บไว้ที่เครื่องกลาง ข้อมูลสำคัญต่างๆ ที่ถูกส่งไปเก็บที่เครื่องกลาง ก็เพื่อใช้ในการพิจารณาถึงการเปลี่ยนแปลงที่เกิดขึ้น และ ใช้ในการกู้คืนระบบ เมื่อระบบเกิดความเสียหาย

Secure Tunnel

ได้ออกแบบช่องทางเพื่อใช้ในการรับส่งข้อมูล เพื่อเป็นการรองรับ CIA คือ ความถูกต้องของข้อมูลที่ส่งว่าไม่โดนแก้ไขข้อมูล มีการยืนยันทั้งทาง ผู้รับและ ผู้ส่ง ว่าเป็นผู้รับผู้ส่งที่เราต้องการจะรับส่งข้อมูลจริงๆ และมีการเข้ารหัสในช่วงที่ทำการรับส่งข้อมูล เพื่อให้เป็นความลับ โดยที่ไม่โดนดักจับข้อมูลไปดูได้โดยง่าย ซึ่งจาก ความต้องการดังกล่าว จึงได้นำ IPsec เข้ามาใช้ในการรับส่งข้อมูลระหว่างเครื่องทั้ง 2 เนื่องจาก IPsec นั้นครอบคลุมทั้ง CIA คือ ความลับ และความถูกต้องของข้อมูล และมีการยืนยันว่าเป็นผู้รับ ผู้ส่ง ที่เราต้องการส่งและรับข้อมูลจริงๆ โดยมีทั้งการ เข้ารหัสข้อมูล และมาการหา HMAC เพื่อใช้ในการตรวจสอบความถูกต้องของข้อมูล และยืนยันตัวด้วยการใช้ password ที่ทั้ง 2 เครื่อง



รูปที่ 3.2 แสดงการรับส่งข้อมูลผ่าน IPsec

Audit & Sensor Syslog-ng

ได้ทำการ อัปเดต จากระบบ syslogd ที่ระบบมีให้มาเป็น syslog-ng ที่มีความสามารถที่หลากหลายกว่า เนื่องจากต้องการที่จะเก็บข้อมูลต่างลงฐานข้อมูล เพื่อให้ง่ายต่อการค้นหา หรือ สืบหาข้อมูล ต่อไป



รูปที่ 3.3 แสดงการเก็บข้อมูลจากโปรแกรม Syslog



รูปที่ 3.4 แสดงการเก็บข้อมูลลงฐานข้อมูล

ในการทำงานนั้น จากระบบ syslog เดิมที่จะเก็บข้อมูลลง Log file ที่เครื่องตัวเองอย่างเดียวก็ให้ทำการส่งข้อมูลไปเก็บที่เครื่อง Log Server ด้วย โดยการส่งที่ผ่าน IPsec เพื่อเป็นการยืนยันผู้ส่ง ผู้รับ ข้อมูลถูกต้อง และข้อมูลที่ได้นั้นเป็นความลับ เพื่อที่จะป้องกันข้อเสียของที่ระบบเดิมๆมี และเมื่อข้อมูลเข้ามาถึงเครื่อง Log Server แล้วตัว Syslog-ng ที่เครื่อง Log Server ก็จะมารับและทำการส่งข้อมูลเข้าไปเก็บที่ใน Log file และเก็บลงฐานข้อมูล

ได้ทำการออกแบบฐานข้อมูลเพื่อใช้ในการเก็บข้อมูลที่ได้อาจมาจากโปรแกรม syslog-ng ดังนี้

```
CREATE TABLE logs ( host varchar(32) default NULL, facility varchar(10) default NULL,
priority varchar(10) default NULL, level varchar(10) default NULL,
tag varchar(10) default NULL, date datetime default NULL,
program varchar(15) default NULL, msg text,
seq int(10) unsigned NOT NULL auto_increment, PRIMARY KEY (seq),
KEY host (host), KEY seq (seq),
KEY program (program), KEY date(date),
KEY priority (priority), KEY facility (facility)
) TYPE=MyISAM;
```

โดยที่ ตัว Sensor ที่บ่งบอกถึงความรุนแรงของเหตุการณ์ต่าง ๆ นั้นสามารถดูได้ที่ ค่า level ต่างๆ ซึ่งได้อธิบายเอาไว้แล้วในเรื่องของ Host based IDS

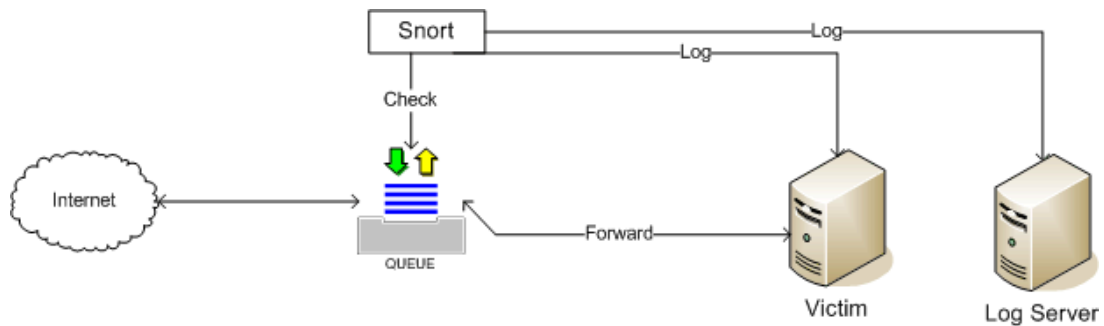
Host Integrity

สำหรับการตรวจสอบความถูกต้องของไฟล์ที่เครื่องนั้น ได้เลือกโปรแกรม samhain มาใช้ในการตรวจสอบความถูกต้องของข้อมูลที่เครื่องก่อนที่จะเก็บข้อมูลลง Log File ที่เครื่องตัวเอง และส่งไปเก็บลงฐานข้อมูลที่เครื่อง Log Server อีกทีโดยผ่าน IPsec



รูปที่ 3.5 แสดงการส่งข้อมูลไปเก็บยังเครื่อง Log Server

Audit & Sensor Network



รูปที่ 3.6 แสดงขั้นตอนการทำงานของโปรแกรม Iptables และโปรแกรม Snort

เมื่อมี packet เข้ามายังเครื่อง เซิร์ฟเวอร์ Iptables ก็จะส่งไปเข้าคิว ก่อน ไม่ว่าจะเป็นการเข้าหรือออกจากเครื่อง เพื่อให้โปรแกรม snort เข้ามาทำการตรวจสอบตัว packet นั้นๆว่า ตรงกับรูปแบบการบุกรุกหรือไม่ ถ้าตรงกับรูปแบบการบุกรุกที่เราตั้งค่าให้ dropทิ้ง และแจ้งเตือนไปยังระบบ หรือว่าอาจจะตรงกับรูปแบบที่กำหนดให้แจ้งเตือนไปยังระบบเท่านั้น และก็ปล่อยให้ผ่านไปก็ได้ หรือถ้าไม่ตรงกับรูปแบบการบุกรุกเลยก็ปล่อยให้ผ่านไปเลย สำหรับ packet ที่ไม่ตรงกับรูปแบบใดเลยนั้น จะไม่เก็บ ข้อมูลลง Log ไฟล์ เนื่องจากข้อมูลจะมากเกินไปจนความจำเป็น

การเก็บข้อมูลที่สำคัญของเครื่อง

การเก็บข้อมูลที่สำคัญของเครื่องจะทำการเก็บไฟล์ที่สำคัญในไดเรกทอรีต่อไปนี้คือ

- /etc เป็นที่เก็บรวบรวมไฟล์คอนฟิกต่างๆของระบบ
- /lib/module เป็นที่เก็บรวบรวมโมดูลที่จะถูกโหลดเข้าเคอร์เนลตอนเริ่มการทำงานของระบบปฏิบัติการ
- /bin , /usr/bin เป็นที่เก็บรวบรวมโปรแกรมสำหรับผู้ใช้งานทั่วไป
- /sbin เป็นที่เก็บรวบรวมโปรแกรมสำหรับ Super User

3.1.2 Forensic

Monitor & Forensics

สำหรับการเฝ้าดูและตรวจสอบระบบนั้นเราสามารถตรวจสอบได้จาก 3 ส่วนหลักๆด้วยกันคือ การดูข้อมูล จาก Host-base IDS , Network-base IDS และ Syslog-ng โดยที่แต่ละตัวจะบอกถึงความรุนแรงของเหตุการณ์ที่เกิดขึ้น และจากจุดนี้เองที่จะเป็นเหมือนจุดที่ให้เราเริ่มตรวจสอบและค้นหาหลักฐาน เมื่อเราพบว่ามีกิจกรรมผิดปกติเกิดขึ้น เราสามารถสืบหาหลักฐานได้โดยเริ่มจากโปรแกรมใดก็ได้ที่แสดงให้เห็นถึงจุดที่น่าสงสัย แต่จุดที่น่าสนใจ ที่จะแนะนำคือ ข้อมูลจาก Host-base IDS ที่เมื่อเรากำหนด policies ไว้ดีแล้วเราจะสามารถตรวจสอบได้ค่อนข้าง

แน่นอนว่าเกิดเหตุการณ์ที่น่าสงสัยขึ้น และค่อนข้างชัดเจนว่าเครื่องเราโดนละเมิดสิทธิ์ไปมาก
เพียงใดแล้ว เพราะในการตรวจสอบจากส่วนนี้ จะไม่มีข้อยกเว้นเหมือน Network-base ที่ไม่
สามารถตรวจสอบเมื่อการสื่อสารระหว่างเครื่องมีการเข้ารหัสอยู่ แต่ว่าจากข้อมูลของ Host-base
IDS เพียงอย่างเดียวก็ไม่สามารถบอกเราได้ว่าเกิดอะไรขึ้น และ ใครมาทำอะไร อย่างไร จึงได้มี
การเปลี่ยนแปลงเกิดขึ้นกับไฟล์นั้นๆ เราจึงต้องมีการนำข้อมูล และหลักฐานที่ได้รวบรวมจากที่
ต่างๆมาช่วยในการสืบหาหลักฐานต่อ คือเมื่อ ทราบว่าไฟล์มีการละเมิดสิทธิ์ โดยที่เราไม่รู้ว่ามีใคร
เป็นคนกระทำ แต่ว่าเรามีเวลาที่เหตุการณ์นั้นๆขึ้น เราสามารถเอาเวลาที่ได้มา ไปตรวจสอบว่า
ในช่วงเวลานี้มีใครบ้างที่ ล็อกอินอยู่ภายในระบบเรา และ เป็นการล็อกอินมาจาก เครื่องอื่น หรือ
ว่ามีการ ล็อกอินเข้ามาผ่านเครื่องๆนั้นเอง ถ้าเป็นการล็อกอินเข้ามาจากเครื่องอื่น ก็ต้องดูต่อไปได้
ว่า เครื่องนั้นมีการติดต่อกันอย่างไรบ้างกับเครื่องเรา และผู้ใช้นั้นมีการใช้คำสั่งอะไรบ้างใน
ช่วงเวลาที่เค้าล็อกอินอยู่บนระบบ โดยรูปแบบการดูและค้นหาข้อมูลจะมีดังนี้

NIDS(Snort)

ส่วนแสดงผลของ จากการตรวจจับผู้บุกรุกจะมีการแสดงผลออกมามีดังนี้

| Index | Signature | Priority | Timestamp | IP_src | IP_dst | Type |

โดย Signature จะบอกว่า Packet นี้เป็นรูปแบบการบุกรุกรูปแบบใด

priority จะบอกถึงความรุนแรงของรูปแบบนั้น

IP_src บอก IP ต้นทาง

IP_dst บอก IP ปลายทาง

Type บอก Protocol ของแพ็กเก็ตที่ใช้ในการสื่อสาร

และสามารถดูข้อมูล data payload ได้โดยการ คลิกไปที่ index

สามารถค้นหาข้อมูลจากส่วนนี้โดย query จาก sensor, signature, signature class, start
time, end time, IP source, IP destination, protocol, source port, destination port, priority และ
payload

Snort

Sensor: any

Signature: hmap

Signature Class: any

Start Time: year any Month any Day any Hour any Min any

End Time: year any Month any Day any Hour any Min any

IP Address: any 0.0.0.0

Proto: any

Port: any 0

Priority: any

PAY LOAD: none

search

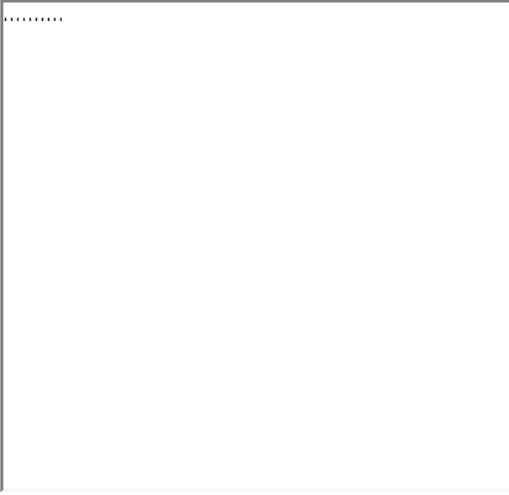
รูปที่ 3.7 แสดงหน้าค้นหาข้อมูลของเครือข่าย

ID	Signature	Priority	Timestamp	Ip_source	Ip_destination	Type
41-(1-4911)	connect ftpd control		2006-02-19 21:09:04	161.246.5.27:33109	161.246.5.32:21	tcp
42-(1-4910)	connect ftpd control		2006-02-19 21:09:04	161.246.5.27:33109	161.246.5.32:21	tcp
43-(1-4909)	connect ftpd control		2006-02-19 21:09:04	161.246.5.27:33109	161.246.5.32:21	tcp
44-(1-4908)	connect ftpd control		2006-02-19 21:09:04	161.246.5.27:33109	161.246.5.32:21	tcp
45-(1-4907)	connect ftpd control		2006-02-19 21:08:59	161.246.5.27:33109	161.246.5.32:21	tcp
46-(1-4906)	connect ftpd control		2006-02-19 21:08:59	161.246.5.27:33109	161.246.5.32:21	tcp
47-(1-4905)	connect ftpd control		2006-02-19 21:08:53	161.246.5.27:33109	161.246.5.32:21	tcp
48-(1-4904)	connect ftpd control		2006-02-19 21:08:52	161.246.5.27:33109	161.246.5.32:21	tcp
49-(1-4903)	connect ftpd control		2006-02-19 21:08:52	161.246.5.27:33109	161.246.5.32:21	tcp
50-(1-4902)	connect ftpd control		2006-02-19 20:45:09	161.246.5.27:33006	161.246.5.32:21	tcp
51-(1-4901)	ICMP PING	3	2006-02-01 21:50:52	161.246.5.32:	12.16.24.128:	icmp
52-(1-4900)	ICMP PING *NIX	3	2006-02-01 21:50:52	161.246.5.32:	12.16.24.128:	icmp
53-(1-4899)	ICMP PING BSDtype	3	2006-02-01 21:50:52	161.246.5.32:	12.16.24.128:	icmp
54-(1-4898)	ICMP PING	3	2006-02-01 21:50:51	161.246.5.32:	12.16.24.128:	icmp
55-(1-4897)	ICMP PING *NIX	3	2006-02-01 21:50:51	161.246.5.32:	12.16.24.128:	icmp
56-(1-4896)	ICMP PING BSDtype	3	2006-02-01 21:50:51	161.246.5.32:	12.16.24.128:	icmp
57-(1-4895)	ICMP PING	3	2006-02-01 21:50:50	161.246.5.32:	12.16.24.128:	icmp
58-(1-4894)	ICMP PING *NIX	3	2006-02-01 21:50:50	161.246.5.32:	12.16.24.128:	icmp
59-(1-4893)	ICMP PING BSDtype	3	2006-02-01 21:50:50	161.246.5.32:	12.16.24.128:	icmp
60-(1-4892)	ICMP PING	3	2006-02-01 21:50:49	161.246.5.32:	12.16.24.128:	icmp

page 3/52
 << [previous] 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 >>
 go to page

back

รูปที่ 3.8 แสดงข้อมูลทางเครือข่าย

Event Payload		
Decode Payload (Binary)	String	Raw Packet
		PA SS t es t@ te st .c om ..

รูปที่ 3.9 แสดงข้อมูล data payload

FILE INTEGRITY

ส่วนที่ใช้แสดงผล จากการตรวจจับการละเมิดสิทธิ์ของไฟล์ ที่เราได้กำหนดไว้มี ดังนี้

| Index | File | Policies | Owner | Severity |

โดยที่ File คือ ชื่อไฟล์ path เต็มที่โดนละเมิดสิทธิ์
 Policies คือ policies ที่ไฟล์นั้นโดนละเมิดสิทธิ์
 Owner คือ เจ้าของไฟล์นั้นๆ
 Severity คือ ความรุนแรงในการละเมิดสิทธิ์

สามารถค้นหาข้อมูลจากส่วนนี้โดย query จาก File, Owner Old, Owner new, Access Time New, Access Time Old, Change Time Old, Change Time New, Modify Time Old, Modify Time New, Severity และ Policies และจากหน้าผลการค้นหาของ File Integrity สามารถเลือกให้แสดงข้อมูลของไฟล์ที่กำหนดได้ โดยหน้าแสดงข้อมูลของไฟล์จะแสดงข้อมูลดังนี้

File	ชื่อไฟล์
Msg	มีการละเมิดไฟล์อย่างไร
CTime-old	เวลาที่ content เปลี่ยนก่อนการละเมิด
CTime-new	เวลาที่ content เปลี่ยนหลังการละเมิด
MTime-old	เวลาที่ค่า Attribute เปลี่ยนก่อนการละเมิด
MTime-new	เวลาที่ค่า Attribute ก่อนการละเมิด

Owner-old	สิทธิ์ก่อนโดนละเมิดสิทธิ์
Owner-new	สิทธิ์หลังโดนละเมิดสิทธิ์
Attr-old	ค่าสิทธิ์การเข้าถึงก่อนโดนละเมิดสิทธิ์
Attr-new	ค่าสิทธิ์การเข้าถึงหลังโดนละเมิดสิทธิ์
Mode-old	ชนิดของไฟล์ก่อนโดนละเมิดสิทธิ์
Mode-new	ชนิดของไฟล์หลังโดนละเมิดสิทธิ์
Size-old	ขนาดไฟล์ก่อนโดนละเมิดสิทธิ์
Size-new	ขนาดไฟล์หลังโดนละเมิดสิทธิ์

จากหน้านี้สามารถแสดงข้อมูลที่เกี่ยวข้องดังนี้

1. ผู้ใช้ที่กำลังใช้งานระบบอยู่ในช่วงเวลานั้น
2. การตรวจสอบ directory ที่เก็บไฟล์ และสามารถเข้าไปทำการตรวจสอบไฟล์ก่อนและหลังถูกละเมิดความปลอดภัย
3. การกู้คืนเฉพาะไฟล์ที่ถูกละเมิดความปลอดภัยให้เป็นไฟล์ก่อนถูกละเมิดความปลอดภัยได้

รูปที่ 3.10 แสดงหน้าค้นหาไฟล์ที่โดนละเมิดความปลอดภัย

Index	File	Policies	TimeStamp	Owner	Sev
23		EXIT	2006-02-01 16:20:31		ALRT
22		---- TIMESTAMP ----	2006-02-01 16:20:12		MARK
21		---- TIMESTAMP ----	2006-02-01 16:19:12		MARK
20		---- TIMESTAMP ----	2006-02-01 16:18:12		MARK
19		---- TIMESTAMP ----	2006-02-01 16:17:12		MARK
18	/etc/passwd	POLICY [ReadOnly] C-----TS	2006-02-01 16:16:42		CRIT
17	/etc/sudoers	POLICY [ReadOnly] C-----UGTS	2006-02-01 16:16:23	www-data	CRIT
16		---- TIMESTAMP ----	2006-02-01 16:15:28		MARK
15		---- TIMESTAMP ----	2006-02-01 16:14:28		MARK
14		---- TIMESTAMP ----	2006-02-01 16:13:28		MARK
13		---- TIMESTAMP ----	2006-02-01 16:12:28		MARK
12		---- TIMESTAMP ----	2006-02-01 16:11:28		MARK
11		---- TIMESTAMP ----	2006-02-01 16:10:28		MARK
10		---- TIMESTAMP ----	2006-02-01 16:09:28		MARK
9		---- TIMESTAMP ----	2006-02-01 16:08:28		MARK
8		---- TIMESTAMP ----	2006-02-01 16:07:28		MARK
7		---- TIMESTAMP ----	2006-02-01 16:06:28		MARK
6		---- TIMESTAMP ----	2006-02-01 16:05:28		MARK
5		---- TIMESTAMP ----	2006-02-01 16:04:28		MARK
4		---- TIMESTAMP ----	2006-02-01 16:03:28		MARK

รูปที่ 3.11 แสดงผลรายชื่อไฟล์ทั้งหมดที่โดนละเมิดความปลอดภัย

จากรูปที่ 3.11 เมื่อคลิกที่ Index ของไฟล์ที่ถูกละเมิดความปลอดภัยจะเป็นการแสดงข้อมูลต่างๆ ของไฟล์ที่โดนละเมิดความปลอดภัย

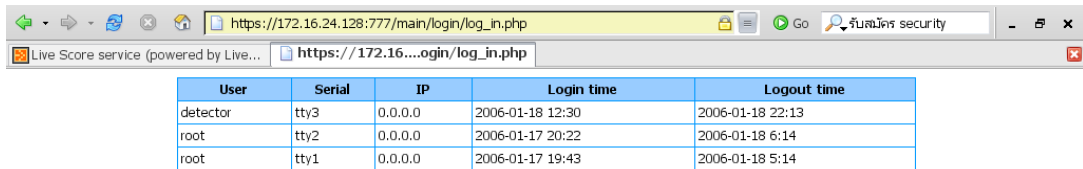
CheckLogin	AddToRestore	CheckDiff
------------	--------------	-----------

File	/etc/passwd		
Msg	POLICY [ReadOnly] C-----TS		
CTime-old	2006-01-31 13:23:01	CTime-new	2006-02-01 16:08:27
MTime-old	2006-01-31 12:39:50	MTime-new	2006-02-01 16:08:27
Owner-old		Owner-new	
Attr-old		Attr-new	
Mode-old		Mode-new	
Size-old	962	Size-new	959

รูปที่ 3.12 แสดงข้อมูลของไฟล์ที่โดนละเมิดความปลอดภัย

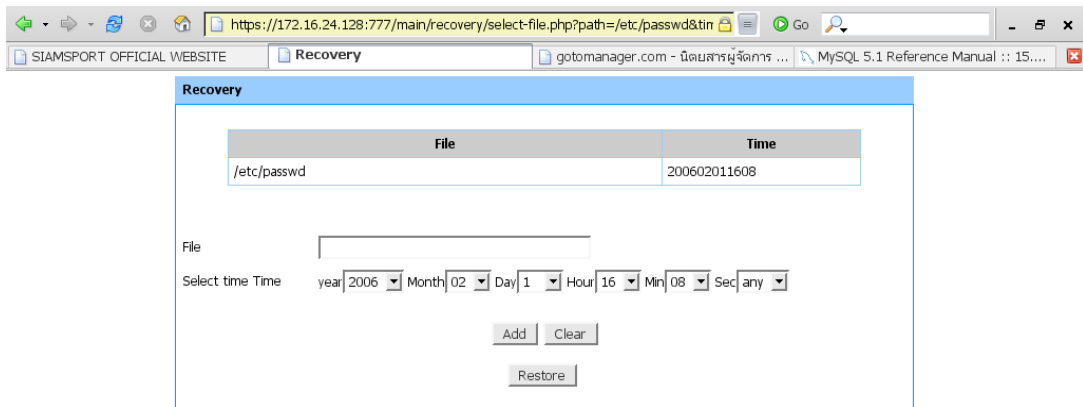
จากรูปที่ 3.12 สามารถตรวจสอบข้อมูลที่มีความสัมพันธ์กับไฟล์ที่ถูกละเมิดความปลอดภัย และตอบสนองต่อการละเมิดความปลอดภัยได้ดังนี้คือ

1. CheckLogin จะทำการค้นหาผู้ใช้ที่ใช้งานระบบอยู่ในช่วงเวลาที่ไฟล์มีการเปลี่ยนแปลง
2. AddToRestore เพื่อทำการ กู้คืนไฟล์ให้เป็นค่าเดิม
3. CheckDiff เพื่อตรวจสอบ โฟลเดอร์ที่เก็บไฟล์ก่อนถูกละเมิดความปลอดภัยและหลังถูกละเมิดความปลอดภัย



User	Serial	IP	Login time	Logout time
detector	tty3	0.0.0.0	2006-01-18 12:30	2006-01-18 22:13
root	tty2	0.0.0.0	2006-01-17 20:22	2006-01-18 6:14
root	tty1	0.0.0.0	2006-01-17 19:43	2006-01-18 5:14

รูปที่ 3.13 แสดงรายชื่อผู้ใช้ที่ใช้งานระบบอยู่ในเวลาเดียวกันกับเวลาที่ไฟล์ /etc/passwd โคนละเมดความปลอดภัย



File	Time
/etc/passwd	200602011608

File

Select time Time year 2006 Month 02 Day 1 Hour 16 Min 08 Sec any

Add Clear

Restore

รูปที่ 3.14 แสดงการกู้คืนไฟล์ที่โดนละเมิดความปลอดภัย

Syslog-ng

ส่วนที่ใช้แสดงผลที่ได้จากการเก็บข้อมูลของระบบ มีดังนี้

| Prog | Msg | Time | Priority | Host Facility |

โดยที่ Prog คือ ชื่อโปรแกรมที่ส่งข้อความแจ้งมายังระบบ

Msg คือ ข้อความที่แจ้งมา

Time คือ เวลาที่ส่งเข้ามา

Priority คือ ความรุนแรงของข้อความที่แจ้งเตือนมา

Host คือ เครื่องที่ส่งเข้ามาเก็บยัง Log Server

Facility คือ ระดับหรือชนิดอย่างเช่น kernel auth เป็นต้น

ส่วนข้อมูลเกี่ยวกับการ login และ command ที่ผู้ใช้ได้ใช้งานจะถูกแสดงแยกอีกที่สามารถค้นหาข้อมูลได้จาก Host, Msg, Facility, Start time, End time และ priority

Host: any

Msg:

Facility: any

Start Time: year any Month any Day any Hour any Min any Sec any

End Time: year any Month any Day any Hour any Min any Sec any

Priority: any

search

รูปที่ 3.15 แสดงหน้าสำหรับค้นหาข้อมูลจากล็อกไฟล์

Index	Prog	Msg	TimeStamp	Priority	Msg	Facility
415	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
414	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
413	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
412	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
411	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
410	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
409	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
408	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
233	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
232	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
231	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
230	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
217	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
216	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
215	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
214	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
183	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
182	sudo	sudo: www-data : TTY=unknown ; PWD=/var/www/inprotect/main/login ; USER=root ; COMMAND=/var/www/inprotect/main/login/get_wtmp.sh	2006-02-01	notice	IPsec6	authpriv
181	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv
180	sudo	sudo: www-data : unable to lookup IPsec6 via gethostbyname()	2006-02-01	alert	IPsec6	authpriv

รูปที่ 3.16 แสดงข้อมูลทั้งหมดจาก ล็อกไฟล์

Login

ส่วนที่แสดงให้คุณคือ

| User | serial | Login Time | Logout Time |

ในส่วนนี้เราต้องกำหนดเวลาที่เราต้องการดู เมื่อป้อนเวลา ก็จะได้ผลลัพธ์เป็นผู้ใช้ที่ล็อกอินอยู่ในช่วงเวลานั้นๆ และสามารถแสดงข้อมูลที่เกี่ยวข้องดังนี้ได้

1. สามารถดูข้อมูลการใช้คำสั่งของผู้ใช้แต่ละคน ในช่วงเวลาที่ใช้งานระบบ จาก เทอร์มินอล นั้นๆได้
2. สามารถดู แพ็กเก็ต ที่เข้า หรือ ออก จากเครื่องนั้นๆ ได้

รูปที่ 3.17 แสดงการค้นหาผู้ใช้งานที่ใช้ระบบในช่วงเวลาที่กำหนด

User	Serial	IP	Login time	Logout time
detector	tty3	0.0.0.0	2006-01-18 12:30	2006-01-18 22:13
root	tty2	0.0.0.0	2006-01-17 20:22	2006-01-18 6:14
root	tty1	0.0.0.0	2006-01-17 19:43	2006-01-18 5:14

รูปที่ 3.18 แสดงรายชื่อผู้ใช้งานที่ใช้ระบบในเวลาที่กำหนด

จากรูปด้านบน สามารถตรวจสอบข้อมูลที่เกี่ยวข้องกันได้อีกดังนี้

1. คำสั่งที่ผู้ใช้งานใช้ในขณะที่ใช้ระบบ สามารถทำการตรวจสอบต่อได้โดยคลิกที่ชื่อผู้ใช้
2. ข้อมูลทางเครือข่ายของเครื่องนั้น สามารถทำการตรวจสอบต่อได้โดยคลิกที่ IP Address

Command	Flag	User	Terminal	Time	Date
bash	F	detector	??	0.00	1 16:07 Feb
bash	F	detector	??	0.00	1 16:02 Feb
bash	F	detector	??	0.00	1 16:02 Feb
clear		detector	??	0.00	1 16:08 Feb
clear		detector	??	0.00	1 16:07 Feb
clear		detector	??	0.00	1 16:06 Feb
id		detector	??	0.01	1 16:05 Feb
clear		detector	??	0.00	1 16:05 Feb
date		detector	??	0.02	1 16:04 Feb
dircolors		detector	??	0.00	1 16:02 Feb
id		detector	??	0.00	1 16:02 Feb

รูปที่ 3.19 แสดงคำสั่งของผู้ใช้ detector ในช่วงเวลาที่กำหนด

3.1.3 Recovery

ในส่วนของการเตรียมการเพื่อทำการกู้คืนระบบนั้นได้ออกแบบการทำงานของระบบออกเป็น 2 ส่วนคือ

ส่วนที่ 1 เป็นส่วนที่ทำการเก็บ snapshot ของ directory ต่างๆ

ในส่วนนี้ได้เลือกใช้โปรแกรม Rsync มาเป็นเครื่องมือสำหรับทำการถ่ายโอนข้อมูลจากเครื่อง Response Wall มาเก็บยังเครื่อง Log Server และทำการบีบอัดด้วยโปรแกรม BZip2 ซึ่งจะทำให้ไฟล์ Snapshot มีขนาดเล็กลงเพื่อเป็นการประหยัดเนื้อที่

คุณสมบัติของโปรแกรม Rsync

- มี Difference Search Algorithm ทำให้สามารถทำ Incremental Backup ได้
- Owner group และ modify time ของไฟล์ต้นฉบับไม่เปลี่ยนแปลง
- มีการบีบอัดไฟล์ก่อนที่จะทำการส่งผ่านเครือข่าย ทำให้สามารถลดความหนาแน่นเนื่องจากปริมาณข้อมูลของเครือข่ายได้

ในการเก็บ Snapshot ได้ออกแบบให้ผู้ดูแลระบบสามารถเลือกระยะเวลาของการเก็บ Snapshot โดยแบ่งเป็นการเก็บแบบหยาบ (Main step) และการเก็บแบบละเอียด (Sub step)

ข้อดีของการเก็บแบบหยาบคือ ประหยัดเนื้อที่ ลด traffic และงานของเครื่อง Response Wall และ Log Server

ข้อดีของการเก็บแบบละเอียดคือ สามารถจัดเก็บไฟล์ที่ใกล้เคียงกับระบบเดิมมากที่สุด โดยเฉพาะในช่วงวิกฤติซึ่งเป็นช่วงเวลาที่ตรวจพบการเริ่มการบุกรุกหรือละเมิดความปลอดภัย จะช่วยทำให้ลดผลกระทบที่อาจเกิดขึ้นกับผู้ใช้ระบบคนอื่นๆ เนื่องจากการกู้คืนระบบ

ในการเลือกหรือปรับแต่งค่าการเก็บ Snapshot นั้นจะอยู่ในรูปของระยะเวลาโดยผู้ดูแลระบบสามารถเลือกได้ว่า จะให้เก็บ Snapshot เป็นระยะเวลาเท่าใด และเก็บทุกๆ ช่วงเวลาเท่าไร ซึ่งโปรแกรมที่ได้ทำการออกแบบไว้จะทำการคำนวณจำนวนของไฟล์ Snapshot ที่จะเก็บให้โดยอัตโนมัติ

ส่วนที่ 2 เป็นส่วนของการกู้คืนระบบ

ในส่วนนี้ได้ทำการออกแบบให้ระบบสามารถทำการวิเคราะห์และค้นหาไฟล์ต้นฉบับที่เหมาะสมจาก Snapshot ที่ได้จัดเก็บไว้ และนำมาเสนอให้กับผู้ดูแลระบบเพื่อการตัดสินใจต่อไป ทั้งนี้จุดเด่นของระบบที่ได้ทำการออกแบบก็คือ การกู้คืนระบบแบบ Selective Restore โดยผู้ดูแลระบบสามารถที่จะเลือกไฟล์ที่ต้องการจะ Restore ได้ จึงไม่มีความจำเป็นที่จะต้องทำการกู้คืนระบบใหม่ทั้งหมด ทำให้สามารถประหยัดเวลา ลดปริมาณข้อมูลที่ต้องผ่านเครือข่าย และลดผลกระทบที่อาจจะเกิดขึ้นกับผู้ใช้งานระบบอื่นๆ

Adding New Path

Path

List Of Path

No.	Path name	Status	Action
1	/lib/modules	Stoped	
2	/etc	Working	
3	/home/detector	Stoped	

Snapshot Configure :

Keep snapshot (Main Step)

Round Reuse
 Years Months Days

Keep snapshot every
 Years Months Days

Keep snapshot (Sub Step)

Round Reuse
 Days Hours

Keep snapshot every
 Hours Minutes

รูปที่ 3.20 แสดงหน้า Snapshot Management

จากรูปที่ 3.20 แสดงในส่วนของการบริหารจัดการการเก็บ Snapshot ซึ่งแบ่งการทำงานเป็นส่วนๆ โดยแต่ละส่วนมีคุณสมบัติดังนี้คือ

1. Adding New Path เป็นส่วนสำหรับการเพิ่ม Path ที่จะให้ระบบทำการเก็บ Snapshot
2. List Of Path เป็นส่วนที่แสดงรายชื่อและสถานะการเก็บ Snapshot ของ Path ที่กำหนด โดยในส่วนนี้สามารถควบคุมการเก็บ Snapshot ดังนี้คือ
 - ปุ่ม Start สำหรับการสั่งให้เริ่มเก็บ Snapshot
 - ปุ่ม Stop สำหรับการสั่งให้หยุดการเก็บ Snapshot
 - ปุ่ม Remove สำหรับการยกเลิกการเก็บ Snapshot และลบไฟล์ Snapshot
3. Snapshot Configure เป็นส่วนที่กำหนดการเก็บ Snapshot
 - Keep Snapshot (Main Step) เป็นการกำหนดการเก็บ Snapshot แบบหยาบโดยมีรายละเอียดดังนี้คือ
 - Round Reuse เป็นการกำหนดช่วงเวลาของไฟล์ Snapshot ที่จะวนทับไฟล์เดิม
 - Keep Snapshot Every เป็นการกำหนดวงจรรอบการเก็บ Snapshot โดยวงจรรอบต่ำสุดคือ 1 วัน

- Keep Snapshot (Sub Step) เป็นการกำหนดการเก็บ Snapshot แบบละเอียดโดยมีรายละเอียดดังนี้คือ
 - Round Reuse เป็นการกำหนดช่วงเวลาของไฟล์ Snapshot ที่จะวนทับไฟล์เดิม
 - Keep Snapshot Every เป็นการกำหนดวงรอบการเก็บ Snapshot โดยวงรอบต่ำสุดคือ 1 นาที

หลังจากที่ได้ทำการปรับแต่งค่าการทำงานของ การเก็บ Snapshot และกดปุ่ม Submit แล้ว การเปลี่ยนแปลงดังกล่าวจะมีผลกับการทำงานของระบบการเก็บ Snapshot ในทันทีโดยไม่ต้องสั่งให้หยุดแล้วเริ่มการเก็บ Snapshot ใหม่